

Enhanced Social Engineering

1. Why AI Fundamentally Changes Social Engineering

Social engineering has always exploited the gap between what security policies require and what human beings naturally do. People extend trust, respond to authority, want to help colleagues, and make decisions under time pressure without complete information. These psychological tendencies are not new vulnerabilities — they are documented, well-understood, and were exploitable long before AI existed. What AI changes is the economics of exploitation.

Traditional spear phishing required skilled social engineers to manually research each target — hours of OSINT work per campaign. Deepfake voice cloning required expensive studio equipment and significant technical expertise. Long-term pretexting relationships required teams of human operatives. AI removes all three constraints simultaneously. The result is a qualitative shift: attacks that previously required nation-state resources or sophisticated criminal organisations are now accessible to modestly resourced attackers. Security awareness programs that were calibrated against generic phishing are not calibrated for this new threat level.

2. LLM-Powered Spear Phishing: From Hours to Seconds

Generic phishing emails fail against security-aware employees because their lack of personalisation is detectable: generic salutations, implausible scenarios, mismatched domains, poor grammar. These detection heuristics are largely irrelevant against LLM-generated spear phishing.

Given a target's name, employer, role, recent LinkedIn activity, and email address — all available from OSINT — an LLM generates a contextually accurate spear phishing email in seconds: referencing the target's recent conference presentation, mentioning a mutual contact by name, using the correct industry vocabulary, and framing a plausible pretext for credential submission or payment approval. What previously required a skilled social engineer to research and write over several hours now requires a prompt and ten seconds. At scale, this means a single attacker can run thousands of personalised spear phishing emails simultaneously — a throughput increase measured in orders of magnitude.

3. Psychological Principles AI Weaponises at Scale

AI-enhanced social engineering does not invent new psychological vulnerabilities. It industrialises exploitation of well-documented influence principles. Understanding which principles are targeted informs effective training countermeasures.

Cialdini Principle	AI Attack Mechanism	Example Attack Vector	Training Countermeasure
Authority	Synthesised voice or deepfake video of executive	CFO deepfake video authorising urgent payment transfer	Out-of-band verification via pre-established channel
Scarcity / Urgency	LLM-generated urgency framing ('deadline is	AI-written phishing email citing imminent	Slowdown rule: urgency requests always require

	today', 'before close of business')	regulatory deadline	verification
Social proof	Fake engagement metrics, fabricated colleague endorsements	Fraudulent Teams message appearing to show multiple colleagues have already approved	Verify through official systems, not message content
Reciprocity	AI chatbot building rapport and small favours before the harmful request	Multi-turn email conversation providing 'helpful information' before requesting credentials	Recognise incremental commitment patterns
Commitment / Consistency	Incremental agreement building — small yes before big yes	AI chatbot agent establishing agreement on minor points before requesting action	Any request for unusual action requires independent verification regardless of prior agreement
Liking	Social graph mapping to identify shared connections for pretexting	Phishing email referencing real mutual contact discovered via LinkedIn	Treat shared-connection references as a risk signal, not a trust signal

4. Pretexting at Scale: AI-Driven Multi-Turn Deception

Pretexting — creating a fabricated scenario to manipulate a target — scales with AI in ways that were not previously possible. A single threat actor can now run dozens of concurrent pretexting scenarios across different targets within the same organisation, each maintaining a coherent false identity, remembering previous conversation details, and adapting to unexpected responses.

LLM-driven chatbot agents conduct multi-turn social engineering conversations via email or messaging platforms, sustaining a plausible identity long enough to establish the trust needed for a harmful request. This long-game pretexting — maintaining contact over days or weeks — was previously limited by the number of human social engineers an attacker could deploy. AI removes that constraint entirely. A single attacker can maintain fifty simultaneous long-term pretexting relationships at the cost of reviewing and approving AI-generated responses.

5. AI-Powered Vishing: Automated Voice Social Engineering

Voice phishing (vishing) campaigns powered by AI dialers combine voice cloning with conversational AI to conduct fully automated phone calls that adapt to the target's responses in real time. Unlike robocall scams that play a fixed script, AI vishing systems conduct genuine conversations — answering questions, handling objections, adjusting the pretext when the target responds unexpectedly.

The target has no reliable indicator that they are not speaking with a human. In some assessments, AI vishing systems outperform human social engineers at remaining calm and consistent under unexpected questioning, because they do not experience the cognitive load of improvisation. Enterprises that rely on

phone-based verification for financial transactions — 'call me back to confirm the wire transfer' — are particularly exposed when the callback number reaches an AI system spoofing the expected party.

Real-World Incident — Multi-Vector AI Social Engineering Campaign Against Manufacturing Firm (2024):

A manufacturing firm was targeted by a coordinated multi-vector campaign. Phase one: LLM-generated spear phishing emails targeted twelve finance department employees, each personalised with references to a recent supplier contract visible in public tender filings. Phase two: three employees who did not click the phishing links received follow-up calls from an AI vishing system cloning the voice of the procurement manager — sourced from a YouTube vendor event video. Phase three: one employee who clicked and entered credentials received a deepfake video message from the 'CFO' explaining payment urgency. The attacker progressed from initial email to fraudulent payment authorisation in seventy-two hours. Total loss: \$840,000. Root cause: no out-of-band financial transaction verification requirement.

6. Smishing and Messaging Platform Attacks

SMS phishing (smishing) and attacks via collaborative messaging platforms — Microsoft Teams, Slack, WhatsApp, Signal — benefit from AI personalisation with an additional advantage over email: perceived legitimacy. A message that appears to come from within an organisation's Teams workspace carries higher implicit trust than an external email, because employees are conditioned to treat internal messages as verified.

AI-enhanced smishing and messaging attacks: generate contextually accurate messages referencing recent conversations (if prior communications were obtained through account compromise or social network analysis); conduct multi-turn conversations across platforms; and impersonate internal contacts by creating look-alike workspace profiles. The migration of business communication to collaborative platforms has created a high-trust channel that attackers are increasingly exploiting as email security controls improve.

7. The Unwitting Insider: Social Engineering and Insider Threat Convergence

AI-enhanced social engineering creates a specific risk at the intersection of external attack and insider threat. An employee who has been socially engineered over an extended pretexting relationship may provide assistance to an attacker without realising they have been manipulated — what security researchers term an 'unwitting insider.'

An LLM agent posing as a new vendor contact, maintained over weeks of email correspondence, can gradually establish the trust needed to request sensitive information, access credentials, or document transfers that the employee provides in good faith. The employee has not been compromised in the traditional sense — they acted with legitimate intent — but the outcome is identical to malicious insider activity. Behavioural analytics that flag unusual data access patterns, even by otherwise trustworthy employees, provide a detection layer for this scenario. The detective control must focus on the action (unusual data export), not the actor's intent.

8. Defensive Architecture: Three-Layer Framework

Defence against AI-enhanced social engineering requires coordinated changes across three layers:

- **Technical layer:** Email authentication (DMARC, DKIM, SPF) prevents domain spoofing; AI-based email scanning detects LLM-generated text patterns and behavioural anomalies; MFA resists credential theft even when credentials are captured; call verification systems can flag AI-synthesised voice characteristics; User Entity and Behaviour Analytics (UEBA) detects anomalous post-compromise behaviour.
- **Process layer:** Mandatory out-of-band verification for all financial transactions above a threshold — phone verification using a pre-registered number, not a number provided in the request; multi-party approval requirements; established code words for sensitive authorisations; callback procedures that use only pre-registered contact information.
- **People layer:** Training that shifts emphasis from detecting visual cues in emails (which AI removes) to recognising social engineering triggers (urgency, authority, unusual request) and following verification process regardless of communication fidelity. The rule is behavioural: 'always verify financial transactions and credential changes out-of-band' — not perceptual: 'look for signs the email is fake'.

Core Principle — Decouple Authorisation from Communication: AI-enhanced social engineering ultimately creates an authenticity problem: any communication can be fabricated with high fidelity. The architectural response is to decouple authorisation from communication — high-stakes decisions (financial transfers, credential changes, data exports) must be verified through a trusted, pre-established mechanism that is independent of and separate from the channel used to make the request. This out-of-band verification principle is one of the most important operational security controls for the AI era, and it is the correct exam answer for questions asking about the appropriate process control against AI-enhanced social engineering.

9. Evolving Security Awareness Training for the AI Era

Traditional phishing awareness training focused on teaching employees to identify visual cues in emails: mismatched domains, generic salutations, poor grammar, suspicious attachments. These cues are largely absent in AI-generated spear phishing. Training calibrated against 2015-era phishing is not calibrated against 2025-era AI spear phishing.

Effective AI-era awareness training shifts from detection to behaviour. The question is not 'does this email look suspicious?' but 'does this request require out-of-band verification regardless of how convincing it looks?' The answer is: yes, for all financial transactions, credential changes, and sensitive data transfers. Training should include:

- Simulated AI-generated spear phishing campaigns (not generic phishing) to calibrate actual susceptibility to this threat level.
- Recognition of Cialdini influence principles in communication — urgency, authority, and social proof as risk signals, not trust signals.
- Verification protocols: specific steps for validating financial requests, with pre-registered callback numbers posted in physical locations (not in email).
- Reporting culture: employees feel safe reporting suspicious interactions without embarrassment; single-click reporting mechanisms in email clients.

- Platforms: KnowBe4 AI-driven phishing simulations, Proofpoint Security Awareness Training AI-powered modules, Cofense — all offered AI-enhanced simulation options as of 2024.

10. Building a Reporting Culture: The Collective Early Warning System

One of the most effective social engineering defences is cultural rather than technical. Many attacks succeed because the target suspected something was wrong but did not report it — worried about seeming paranoid, embarrassed about falling for a manipulation attempt, or reluctant to appear to distrust a senior colleague.

Organisations that actively reward reporting of suspicious contacts — and that respond without blame even when the report is a false positive — build a collective early warning system that provides operational security value. Each employee who reports becomes a sensor. The earlier a suspicious contact is reported, the sooner the security team can assess whether it represents an active campaign. This cultural control is reinforced by: regular security leadership communication about active threats; simple, low-friction reporting mechanisms (one-click in the email client, a dedicated Slack channel, a posted phone number); and visible positive responses when reports identify real threats.

11. Red Team Application and Ethical Constraints

Red teams and authorised phishing simulation vendors use AI to test organisational resilience against LLM-enhanced spear phishing and vishing. The value is twofold: revealing which employee populations are most vulnerable to personalised attacks (distinct from generic phishing susceptibility), and calibrating training programs to the current attack fidelity level.

Authorised social engineering testing operates within ethical and legal constraints. NIST SP 800-115 provides technical guidance for social engineering testing within an authorised penetration testing framework. Key constraints:

- Explicit written authorisation from appropriate organisational authority — not just IT department sign-off.
- Defined scope: which employee populations are in scope, which pretexts are permitted (pretexts targeting employees known to be in personal distress are generally excluded).
- Sensitive debriefing: post-engagement communication focuses on organisational learning, not individual performance; employees who fell for simulations are not named publicly.
- Legal compliance: CFAA in the US, CMA in the UK; social engineering tests that cause significant psychological distress may create HR and legal liability.
- ATT&CK classification: Spear phishing is T1566.002 (Spearphishing Link) or T1566.001 (Attachment); vishing is T1566.004 (Spearphishing Voice); these are Initial Access techniques.

Key Terms Glossary

Term	Definition
Spear phishing	A targeted phishing attack personalised to a specific individual using information gathered through reconnaissance. ATT&CK T1566.001/.002.

Vishing	Voice-based phishing — phone calls designed to manipulate targets into disclosing information or taking harmful actions. ATT&CK T1566.004.
Smishing	SMS-based phishing using text messages to deliver social engineering attacks.
Pretexting	Creating a fabricated scenario (pretext) to manipulate a target into providing information or taking a harmful action.
Unwitting insider	An employee who has been socially engineered into providing assistance to an attacker without realising they have been manipulated.
Out-of-band verification	Verifying a request through a channel independent of the one used to make the request — e.g., calling a pre-registered number to confirm a payment request received by email.
Cialdini's influence principles	Six psychological principles (authority, scarcity, social proof, reciprocity, commitment, liking) documented by Robert Cialdini that AI social engineering systematically exploits.
DMARC / DKIM / SPF	Email authentication protocols that prevent spoofing of an organisation's domain in email. Technical controls that address one dimension of social engineering attack infrastructure.
UEBA (User and Entity Behaviour Analytics)	Analytics systems that detect anomalous user behaviour patterns — useful for identifying unwitting insiders who have been socially engineered.
NIST SP 800-115	NIST technical guide for information security testing and assessment, including social engineering testing within an authorised penetration testing scope.
T1566 (ATT&CK)	The ATT&CK technique covering phishing — sub-techniques include .001 (attachment), .002 (link), .004 (voice/vishing).
PR.AT (NIST CSF 2.0)	The Awareness and Training category in NIST CSF 2.0 — the relevant CSF category for security awareness training as a social engineering preventive control.

Quick Revision Checklist

- AI changes social engineering economics: spear phishing drops from hours of research to seconds per target, enabling orders-of-magnitude scale increase.
- LLM-generated spear phishing removes the visual cues (grammar, generic salutation) that traditional awareness training teaches employees to detect.
- AI vishing systems clone real voices and conduct genuine conversations — phone-based verification is not reliable without out-of-band callback procedures.
- Cialdini's six influence principles (authority, scarcity, social proof, reciprocity, commitment, liking) are the psychological mechanisms AI exploits — train employees to recognise them as risk signals.
- Pretexting scales to dozens of concurrent long-term relationships managed by LLM agents — the 'unwitting insider' is the resulting risk category.
- Multi-vector attacks (email + vishing + deepfake video) compress the attack timeline — the 2024 manufacturing case achieved payment fraud in 72 hours.

- Defence architecture: technical (DMARC, AI email scanning, MFA, UEBA) + process (out-of-band verification, multi-party approval) + people (behaviour-focused training, reporting culture).
- Out-of-band verification is the single most important process control: decouple authorisation from communication channel for all high-stakes requests.
- Awareness training must shift from detection ('does this look fake?') to behaviour ('always verify out-of-band regardless of how convincing it looks').
- Reporting culture — employees reporting without fear of embarrassment — creates a collective early warning system; reward reporting, including false positives.
- ATT&CK classification: T1566.001 (attachment), T1566.002 (link), T1566.004 (vishing) — all Initial Access techniques.
- NIST CSF 2.0: PR.AT covers awareness and training (prevention); DE.AE covers anomalous event detection (the UEBA layer).

10 Exam-Based MCQs — Enhanced Social Engineering

Test yourself after reading. These questions are written in exam style — scenario-heavy with plausible distractors. Read every explanation, including for questions you answered correctly.

Q1. Scenario: A manufacturing firm suffered an \$840,000 loss after a coordinated attack combining AI-generated personalised phishing emails, an AI vishing call cloning the procurement manager's voice, and a deepfake video of the CFO. Three separate finance employees were targeted before one authorised the payment. Which process control would MOST effectively prevent a recurrence of this attack?

- A) Deploy AI-based email scanning to detect LLM-generated content
- B) Require mandatory out-of-band verification for all financial transactions using pre-registered contact information
- C) Conduct quarterly phishing awareness training for all finance employees
- D) Implement DMARC enforcement to prevent domain spoofing

Answer: B **Explanation:** B is correct because the attack succeeded by making a fraudulent payment authorisation convincing through multiple channels (personalised email, voice clone, deepfake video). No amount of email scanning or awareness training addresses the root architectural vulnerability: authorisation was coupled to communication channel. Out-of-band verification via pre-registered contact information decouples them — even if all communications are perfectly convincing fakes, the verification call to the pre-registered number exposes the fraud. A is wrong — AI email scanning helps with initial delivery detection but the employee who ultimately authorised the payment did so after receiving a deepfake video, not just an email. C is wrong — awareness training alone did not prevent this attack; the training must specifically change authorisation behaviour, not just detection awareness. D is wrong — DMARC prevents spoofing of the organisation's exact domain but does not address voice cloning, deepfake video, or social engineering through legitimate-looking channels.

Q2. A finance employee receives an urgent email from the CFO requesting an immediate wire transfer, referencing a deal the employee knows is real. The employee is trained to look for signs of phishing. Which training emphasis would BEST prevent this attack from succeeding?

- A) Teaching employees to check the sender email domain for spoofing indicators
- B) Teaching employees to verify financial requests out-of-band regardless of how convincing the communication appears
- C) Training employees to identify grammatical errors in AI-generated phishing emails
- D) Requiring employees to forward suspicious emails to the security team before acting

Answer: B **Explanation:** B is correct because AI-generated spear phishing removes the visual cues (grammar errors, generic salutations, domain spoofing) that traditional detection-focused training addresses. The correct emphasis is behavioural: 'always verify financial transactions out-of-band' — a rule that applies regardless of how convincing the communication looks. A is wrong — AI-generated phishing increasingly uses legitimate email infrastructure or accurately spoofed domains; domain inspection alone is insufficient against sophisticated attacks. C is wrong — LLM-generated phishing emails have correct grammar; this heuristic is not effective against AI-enhanced attacks. D is wrong — forwarding the email to the security team introduces delay but does not provide the employee with a reliable decision rule; the out-of-band verification rule is more direct and effective.

Q3. Which Cialdini influence principle is MOST directly exploited by an AI vishing system that clones a CEO's voice to create urgency around an immediate payment authorisation?

- A) Reciprocity
- B) Authority combined with scarcity
- C) Social proof
- D) Commitment and consistency

Answer: B **Explanation:** B is correct. Cloning the CEO's voice exploits authority (the target believes they are speaking with a senior executive whose instructions carry implicit power to override normal procedures). The urgency framing ('immediate', 'before close of business') exploits scarcity/urgency (time pressure that prevents careful deliberation and verification). These two principles are typically combined in high-value payment fraud attacks because together they produce the strongest compliance response. A is wrong — reciprocity involves building a sense of obligation through prior favours; it is not the primary mechanism in a direct payment instruction. C is wrong — social proof exploits the perception that peers have already taken the same action; it is not relevant in a direct CEO instruction scenario. D is wrong — commitment and consistency exploits prior agreement to make a final request harder to refuse; it requires prior interaction, not an urgent one-off call.

Q4. An employee has been corresponding by email with what appears to be a new vendor contact for three weeks, providing progressively more detailed information about internal systems in response to apparently reasonable vendor onboarding questions. This BEST exemplifies which attack pattern?

- A) A supply chain attack targeting the vendor
- B) Long-term AI-assisted pretexting resulting in an unwitting insider
- C) A credential phishing campaign using a spear phishing link
- D) Data poisoning through email interaction data

Answer: B **Explanation:** B is correct. The pattern — sustained multi-turn email correspondence building

trust over weeks before extracting sensitive information — is the definition of long-term pretexting. The employee is an unwitting insider: they provided assistance without realising they were being manipulated. The AI element is the LLM agent maintaining the vendor persona across three weeks of consistent, contextually appropriate responses. A is wrong — a supply chain attack involves compromising a vendor to gain access to the target; this scenario describes a direct attack on the employee using a fabricated vendor identity. C is wrong — a credential phishing campaign targets login credentials via a link; this attack targeted internal system information through a trust relationship, not credentials via a link. D is wrong — data poisoning targets ML model training pipelines, not information disclosure through email correspondence.

Q5. Which MITRE ATT&CK sub-technique covers AI-powered voice phishing (vishing)?

- A) T1566.001 — Spearphishing Attachment
- B) T1566.002 — Spearphishing Link
- C) T1566.004 — Spearphishing Voice
- D) T1598.003 — Spearphishing Link (Reconnaissance)

Answer: C **Explanation:** C is correct. MITRE ATT&CK T1566.004 — Spearphishing Voice — covers voice-based phishing attacks, including AI-powered vishing that uses synthesised or cloned voices to conduct phone-based social engineering. It is an Initial Access technique. A is wrong — T1566.001 covers phishing that delivers malicious attachments via email. B is wrong — T1566.002 covers phishing that delivers malicious links via email. D is wrong — T1598.003 is a Reconnaissance technique covering credential phishing during the pre-attack phase, not Initial Access via voice.

Q6. Which NIST CSF 2.0 category covers security awareness training as a preventive control against AI-enhanced social engineering?

- A) DE.AE — Anomalies and Events
- B) PR.AT — Awareness and Training
- C) RS.CO — Incident Response Communications
- D) GV.OC — Organisational Context

Answer: B **Explanation:** B is correct. PR.AT (Protect: Awareness and Training) is the NIST CSF 2.0 category that directly covers security awareness and training programs as preventive controls. It includes training employees to recognise social engineering techniques and to follow verification procedures. A is wrong — DE.AE (Detect: Anomalies and Events) is the detection category; it covers UEBA-type monitoring for anomalous behaviour patterns — useful for detecting unwitting insider outcomes, but not the training preventive control. C is wrong — RS.CO covers communications during incident response, not preventive awareness training. D is wrong — GV.OC covers organisational context at the governance level, not specific security training programs.

Q7. A security team wants to assess organisational susceptibility specifically to AI-enhanced spear phishing. Which approach provides the MOST relevant data?

- A) Run a standard generic phishing simulation using a common lure template

- B) Review historical phishing click rates from the past 12 months
- C) Run AI-generated personalised spear phishing simulations targeting specific employees
- D) Administer a written quiz on phishing awareness to all employees

Answer: C **Explanation:** C is correct. Susceptibility to AI-enhanced spear phishing is a distinct measurement from susceptibility to generic phishing — employees who pass generic phishing simulations may still be highly susceptible to personalised, contextually accurate attacks. Running AI-generated personalised simulations (as offered by KnowBe4, Proofpoint, and Cofense as of 2024) provides data that is directly relevant to the current threat. A is wrong — generic phishing templates measure susceptibility to the much less sophisticated attack that employees have been trained against; the results do not predict performance against AI spear phishing. B is wrong — historical generic phishing click rates do not measure susceptibility to the personalised AI attack vector. D is wrong — a written quiz measures knowledge, not actual behaviour under realistic attack conditions.

Q8. Which technical control is MOST effective at reducing the success rate of AI-generated spear phishing emails that use a newly registered lookalike domain?

- A) Endpoint detection and response (EDR) behavioural monitoring
- B) DMARC enforcement on the organisation's own domain combined with email gateway filtering for newly registered domains
- C) Network intrusion detection system (IDS) signature updates
- D) Multi-factor authentication (MFA) for all user accounts

Answer: B **Explanation:** B is correct. A lookalike domain attack uses a newly registered domain that resembles the target organisation's domain (e.g., corp0rate.com for corporate.com) — DMARC enforcement on the organisation's own domain prevents spoofing of the exact domain, but not lookalike domains. Email gateway filtering specifically targeting newly registered domains (domains registered within the past 30 days, which are disproportionately associated with phishing) adds protection against the lookalike domain vector. Together these address both the direct spoofing and lookalike vectors. A is wrong — EDR monitors endpoint execution behaviour; it does not filter email at delivery. C is wrong — IDS signatures detect network attack patterns; they do not inspect email content or sender domain properties. D is wrong — MFA protects accounts after credentials are compromised; it does not prevent the phishing email from reaching and deceiving the employee.

Q9. An organisation is designing authorised social engineering testing. Which constraint is MOST important to establish in writing before testing begins?

- A) The specific LLM model to be used for generating phishing content
- B) Explicit written authorisation defining scope, permitted pretexts, and excluded populations
- C) The target click-rate benchmark from previous simulations
- D) The security awareness training vendor's pricing for remediation training

Answer: B **Explanation:** B is correct. NIST SP 800-115 and responsible penetration testing practice require explicit written authorisation that defines scope (which populations are in scope), permitted pretexts (which scenarios are allowed, and which are prohibited — e.g., pretexts exploiting known personal distress), and any excluded individuals. Without this documentation, the testing team lacks legal protection

and the organisation lacks assurance that the test is conducted within agreed parameters. A is wrong — the specific AI model used is an implementation detail, not a legal or ethical prerequisite. C is wrong — previous click rates are a benchmark for measuring improvement but are not a prerequisite for authorisation. D is wrong — vendor pricing is a commercial consideration, not an ethical or legal constraint that must be established before testing.

Q10. Which combination of controls BEST addresses the full threat model of AI-enhanced social engineering?

- A) AI email scanning + DMARC + employee awareness training focused on visual phishing cues
- B) Out-of-band verification process + AI-enhanced email scanning + behaviour-focused awareness training + UEBA for unwitting insider detection
- C) Network segmentation + IDS + MFA + endpoint encryption
- D) Penetration testing + vulnerability management + security awareness quiz

Answer: B **Explanation:** B is correct because it addresses the full threat model across process, technical, and people dimensions: out-of-band verification (process — decouples authorisation from manipulable communication channel), AI-enhanced email scanning (technical — detects LLM-generated text patterns and anomalous sender behaviour), behaviour-focused awareness training (people — teaches verification protocol rather than cue detection), and UEBA (technical — detects anomalous data access by unwitting insiders who have been socially engineered). Together these layers address initial delivery, employee decision-making, and post-compromise activity. A is wrong — visual phishing cue training is not calibrated for AI-generated spear phishing; this combination is a pre-AI era defence stack. C is wrong — network segmentation, IDS, and encryption are infrastructure controls that do not address social engineering attacks that operate through legitimate communication channels and legitimate user credentials. D is wrong — penetration testing, vulnerability management, and quizzes are important security programme components but do not constitute a defence architecture specifically targeting AI-enhanced social engineering.